

Security+ 2.2 · Phishing

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.2 — Phishing (6:32) · [vídeo original ↗](#) · [YouTube ↗](#)

Fraude por email: phishing em massa; Spear phishing = alvo específico com contexto pessoal; Whaling = mirando EXECUTIVO (a baleia); Vishing = por voz (ligação); SMiShing = por SMS. Defesa: MFA, antispam, SPF/DKIM/DMARC (autentica o remetente), awareness.

Highlights que a prova cobra

- Whaling = phishing mirando executivo (spear phishing de whale)
- Vishing = phishing por VOZ; SMiShing = por SMS
- SPF/DKIM/DMARC: o trio de autenticação de remetente de email

Dicas de prova

- 'C-level executives target' = whaling
- 'phishing by voice call' = vishing

Cenário clássico: Cenário típico: 'email urgente se passando pelo CFO pedindo transferência' = whaling/BEC — não phishing genérico.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?

- A)** BEC / CEO fraud (fraude do CEO)
- B)** Whaling
- C)** Vishing
- D)** Tailgating

2. Um atacante envia e-mails direcionados a executivos específicos com informações personalizadas da empresa. Que técnica de engenharia social é essa?

- A)** Vishing
- B)** Whaling
- C)** Spam
- D)** Pharming

3. Um funcionário recebe ligação de alguém se passando por suporte técnico solicitando senha para 'atualização do sistema'. Que técnica é essa?

- A)** Vishing
- B)** Pretexting
- C)** Baiting
- D)** Tailgating

4. Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:

- A)** Escassez
- B)** Autoridade + urgência
- C)** Prova social
- D)** Reciprocidade

5. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Whaling = phishing mirando executivo (spear phishing de whale)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Whaling = phishing mirando executivo (spear phishing de whale)...

6. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Vishing = phishing por VOZ; SMiShing = por SMS'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Vishing = phishing por VOZ; SMiShing = por SMS...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'SPF/DKIM/DMARC: o trio de autenticação de remetente de email'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: SPF/DKIM/DMARC: o trio de autenticação de remetente de email...

8. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'C-level executives target' = whaling'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'C-level executives target' = whaling...

9. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'phishing by voice call' = vishing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'phishing by voice call' = vishing...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Phishing): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'email urgente se passando pelo CFO pedindo transferência' = whaling/BEC — não phishing genérico.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário típico: 'email urgente se passando pelo CFO pedindo transferência' ...

GABARITO COMENTADO

- 1) A — BEC / CEO fraud (fraude do CEO).** BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima)
- 2) B — Whaling.** Whaling é spear phishing direcionado especificamente a executivos de alto nível (C-level) com conteúdo personalizado.
- 3) A — Vishing.** Vishing = phishing por VOZ/telefone (a 'ligação' é a chave). O golpista finge ser o suporte pra extrair a senha. (Pretexting é a técnica do cenário inventado, muitas vezes usada JUNTO com o vishing.)
- 4) B — Autoridade + urgência.** Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro.
- 5) D — Implementar a solução correspondente: Whaling = phishing mirando executivo (spear).** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Phishing): Whaling = phishing mirando executivo (spear phishing de whale). As demais alternativas configuram violações graves de conformidade
- 6) C — Implementar a solução correspondente: Vishing = phishing por VOZ; SMiShing = por SMS.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Phishing): Vishing = phishing por VOZ; SMiShing = por SMS. As demais alternativas configuram violações graves de conformidade ou falhas
- 7) D — Implementar a solução correspondente: SPF/DKIM/DMARC: o trio de autenticação de remetente.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Phishing): SPF/DKIM/DMARC: o trio de autenticação de remetente de email. As demais alternativas configuram violações graves de conformidade
- 8) D — Implementar a solução correspondente: 'C-level executives target' = whaling....** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Phishing): 'C-level executives target' = whaling. As demais alternativas configuram violações graves de conformidade ou falhas de controle
- 9) B — Implementar a solução correspondente: 'phishing by voice call' = vishing....** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Phishing): 'phishing by voice call' = vishing. As demais alternativas configuram violações graves de conformidade ou falhas de controle
- 10) D — Implementar a solução correspondente: Cenário típico: 'email urgente se passando pelo CFO pedindo transferência' = whaling/BEC — não phishing genérico..** As demais alternativas configuram violações graves de conformidade ou falhas de controle

